

DECODELABS · CYBER SECURITY · PROJECT 3

Phishing Awareness Analysis

A Threat-Identification & Triage Toolkit for the Human Firewall

Sample message analysis · Red-flag taxonomy · Triage decision tree · Employee checklist

Project Name	Phishing Awareness Analysis
Track	Cyber Security – Threat Identification
Project Number	Project 3 of the Internship Series
Deliverables	Analysis report · Red-flag taxonomy · Triage toolkit
Companion Tool	Phishing Triage Analyzer (HTML/JavaScript)
Organization	DecodeLabs
Batch	2026
Project made by	Dinesh Lal Das

Contents

Contents	2
1. Executive Summary	3
2. The Phishing Threat Landscape	4
2.1 The hierarchy of email targeting	4
2.2 Channels beyond the inbox	4
3. Technical Disguises: Headers & URLs	6
3.1 Email header manipulation	6
3.2 Lookalike domains	6
3.3 Reading a URL: the right-to-left rule	6
3.4 URL shorteners — the hidden-domain problem	7
4. The Psychology: Cognitive Triggers	8
5. The Red-Flag Catalogue	9
6. Sample Message Analysis	10
6.1 Urgent CEO Wire-Transfer Request (BEC / Whaling)	10
6.2 “Your Account Security Alert” (Credential Harvesting)	10
6.3 “CEO Lost-Wallet” SMS (Smishing / BEC)	11
6.4 “Subscription Payment Failed” (SaaS Brand Impersonation)	12
6.5 Q3 Project Status Update (Legitimate — Control Sample)	12
7. The Phishing Triage Toolkit	14
7.1 Decision tree	14
7.2 Analyst standard operating procedure (header & URL checks)	14
8. Employee Red-Flag Checklist	15
9. Building Resilience: Simulation & Ethics	16
9.1 Ethical template design	16
9.2 The continuous loop	16
10. Conclusion	17

1. Executive Summary

Phishing is the single most common entry point for security breaches. Industry data referenced in this project shows roughly 80% of breaches involve phishing, and in a controlled red-team simulation about 40% of employees fell for a phishing/vishing campaign — with the first click landing, on average, only 82 seconds after a campaign launches. The modern security perimeter is no longer the network firewall; it is the user.

This report is the deliverable for Project 3: Phishing Awareness Analysis. It does three things. First, it dissects five realistic sample messages and explains, line by line, the red flags that mark each as unsafe. Second, it organizes those observations into a reusable taxonomy of phishing types, technical disguises, and psychological triggers. Third, it turns analysis into action with a non-expert triage checklist and a decision tree that ends every suspicious message in a definitive outcome: Close, Warn, or Block & Escalate.

The golden rule throughout this report

Pause — recognize the cognitive trigger (urgency, fear, authority) and stop interacting.

Verify — confirm the request through a separate, out-of-band channel using a known contact.

Report — use the internal reporting tool; do not just delete, so the threat can be purged everywhere.

2. The Phishing Threat Landscape

Before analyzing individual messages, an analyst needs a mental map of the threat. Every social-engineering attack follows the same three-stage anatomy: the Input (the bait — how the lure is delivered and weaponized), the Process (the psychology — the cognitive triggers that push a user to bypass logic), and the Output (the defense — how we architect detection and triage). The rest of this report follows that same flow.

2.1 The hierarchy of email targeting

Phishing ranges from mass, low-effort lures to surgically personalized attacks aimed at executives. The more targeted the attack, the harder it is to spot and the higher the payoff for the attacker.

Type	How it works	Tell-tale signs
Mass Phishing	Generic lures mimicking ubiquitous brands (Amazon, PayPal). High volume, low personalization; roughly 1% engagement.	No name used; generic greeting; brand mismatch.
Spear Phishing	Contextual precision. Attackers use OSINT (e.g. LinkedIn) to reference real project names, colleagues, or internal jargon.	Accurate details but an off domain or odd reply-to.
Whaling / BEC	Targets the C-suite. Focuses on founders and executives to execute high-value wire transfers (BEC) or acquire M&A documents.	Executive impersonation; secrecy; urgent money movement.

Real-world impact: The Quanta Computer exploit

A single attacker stole over **\$100 million** from Google and Facebook — not with a zero-day, but with targeted spear-phishing. By spoofing the domain of a legitimate Taiwanese hardware supplier (Quanta) and forging supporting invoices, the attacker bypassed finance-department checks completely. Sophisticated impersonation beats even the most secure networks.

2.2 Channels beyond the inbox

Threat actors exploit communication channels well beyond email. An analyst must triage all of them.

Channel	Description
Smishing (SMS)	Malicious links delivered via text, often disguised as package deliveries or urgent bank alerts.
Vishing (Voice)	Live calls using caller-ID spoofing to impersonate IT support or government agencies.
Quishing (QR)	Malicious QR codes on physical posters or inside digital PDFs, forcing users onto mobile devices where spoofed domains are harder to spot.

Channel	Description
Search-Engine Phishing	SEO poisoning that pushes malicious lookalike sites above the legitimate login portal in search results.

3. Technical Disguises: Headers & URLs

Most red flags hide in two places a casual reader never inspects: the real sender address behind the display name, and the true root of a URL behind friendly-looking text. This section documents the standard operating procedure for parsing both — the core of the project mandate to document SOPs for From / Return-Path headers and suspicious subdomains.

3.1 Email header manipulation

Technique	What the analyst must check
Display-Name Spoofing	The trick: The client shows a trusted friendly name (e.g. “CEO Name”), but the underlying address is a rogue external domain such as hacker@gmail.com. Mobile clients hide the real address and are especially vulnerable. The SOP: Expand the header and read the actual email address, not the display name.
True-Domain Spoofing	The trick: The From address appears to match the company domain exactly, often because the target domain lacks SPF, DKIM, and DMARC authentication. The SOP: Check authentication results and the Return-Path. A failing or mismatched SPF/DKIM/DMARC result on a From that matches your own domain is a strong malicious indicator.

The Triage Mandate

Always inspect the full email headers — never trust the standard preview view alone.

3.2 Lookalike domains

Attackers register domains that deceive the human eye. Learn the three families:

Family	Method	Example
Typosquatting	Registering common, easily missed misspellings of a real brand.	amaz0n.com (zero for o)
Homoglyph attacks	Substituting visually identical characters from a different alphabet.	paypal.com with a Cyrillic “a”
Combosquatting	Adding security-related words to a legitimate brand name to look more official.	yourcompany-secure-login.com

3.3 Reading a URL: the right-to-left rule

Attackers bury a malicious root domain at the end of a long, legitimate-looking string. The browser only cares about the true root domain, which sits immediately before the first single slash. Always read a URL from right to left to find the real destination.

Worked example — the subdomain trap

www.decode labs . tech . login - update . com

Fake subdomain: www.decode labs . tech — looks trustworthy, but it is only a label.

True root domain: login - update . com — this is who actually owns the page. Verdict: malicious.

Dangling DNS takeover (advanced)

When a company deletes a cloud resource (e.g. an AWS S3 bucket) but forgets to remove the CNAME record in DNS, an attacker can provision a new resource with the same name and take over a trusted corporate subdomain. SOP: periodically audit DNS for records pointing at de-provisioned resources.

3.4 URL shorteners — the hidden-domain problem

Shortened links (bit.ly, tinyurl, t.co and similar) strip away every clue an analyst relies on: the brand, the spelling, and the true root domain all disappear behind an opaque slug. This is exactly the “url-shortener” angle suggested in the project brief, and it deserves its own rule.

- **Never click to expand.** Treat a shortened link in an unsolicited message as untrusted by default.
- **Preview safely.** Many shorteners reveal the destination by appending a “+” to the link or by using a trusted URL-expander/sandbox service rather than a live click.
- **Distrust shorteners from “official” senders.** Banks, IT, and payroll rarely hide their real domain behind a shortener — a shortened “bank” link is itself a red flag.
- **Hover before trust.** On desktop, hover to reveal the expanded target in the status bar; on mobile, long-press to preview rather than tap.

4. The Psychology: Cognitive Triggers

Technical disguises get a message into the inbox; psychology is what makes a user act against their own judgment. Attackers engineer messages to fire one of four cognitive triggers that short-circuit rational verification. Naming the trigger is the first step of the Pause.

Trigger	How attackers weaponize it
Authority	Impersonating the C-suite, IT, or law enforcement to demand unquestioned compliance.
Urgency	Manufacturing artificial time pressure (“Account locked in 30 minutes”) to trigger a fight-or-flight response and reduce rational processing.
Curiosity	Exploiting the human need to close a knowledge gap (“See what your colleague said about you”).
Fear / Greed	Threatening negative consequences (legal action) or promising unearned rewards (unexpected prize giveaways).

Analyst heuristic

If a single message combines **authority + urgency + a request to bypass normal procedure**, treat it as malicious until proven otherwise. That combination is the signature of Business Email Compromise.

5. The Red-Flag Catalogue

These are the eleven indicators an analyst scans for in any incoming message. They are the working vocabulary used in the sample analysis (Section 6) and the employee checklist (Section 8).

#	Red flag	What it looks like
1	Sender-domain mismatch	The display name conflicts with the actual routing domain (e.g. “Microsoft Support” sending from support@logins-updates.com).
2	Fake forwarded chains	FW: threads containing pasted headers and odd timestamps for conversations the user was never part of, used to manufacture legitimacy.
3	Browser-in-the-Browser (BitB)	A fake single-sign-on pop-up that cannot be dragged outside the main browser window because it is just an image in the page.
4	Dangerous attachments	Uncommon file extensions (.iso, .js, .scr) or HTML-smuggling files posing as standard documents.
5	Urgent bypass requests	Demands for secrecy or explicit instructions to bypass normal procurement/security procedures.
6	Requests for sensitive info	Unexpected prompts for MFA codes, passwords, or payment-detail changes over email.
7	Activity alerts that link out	Alarmist “unusual sign-in” warnings that point straight to a login page instead of advising manual navigation.
8	MFA fatigue	Multiple unprompted authenticator push notifications designed to wear the user down until they tap Approve.
9	Callback scams (TOAD)	Emails with no link, only a phone number, urging the user to call “support” about a fake charge.
10	QR-code prompts	Unsolicited QR codes demanding a scan to “secure” an account, bypassing desktop URL filters entirely.
11	Deepfake live-meeting fraud	Audio or video impersonation of an executive during an ad-hoc meeting, demanding mid-call vendor payment changes.

6. Sample Message Analysis

This section delivers the core requirement of Project 3: analyze sample messages, identify suspicious links/keywords, list the red flags, and explain why each message is unsafe. Five samples are dissected below, each ending in a triage verdict.

6.1 Urgent CEO Wire-Transfer Request (BEC / Whaling)

Attack class: Business Email Compromise — executive impersonation

From: CEO - STRICTLY CONFIDENTIAL <ceo.urgent@executive-update.com>
Subject: IMMEDIATE ACTION REQUIRED: Transfer Authorization
Body: URGENT: Process the attached wire-transfer instruction immediately.
This is critical and must remain STRICTLY CONFIDENTIAL.
Do not discuss with anyone. Bypass standard procedure. Thank you.

Red flags identified

- **Sender-domain mismatch** — the friendly name says “CEO” but the real domain is executive-update.com, not the company domain.
- **Urgent bypass request** — explicit instruction to “bypass standard procedure” and act “immediately.”
- **Demand for secrecy** — “strictly confidential / do not discuss with anyone” isolates the target from colleagues who would spot the fraud.
- **Authority + urgency trigger** — impersonated executive authority stacked with manufactured time pressure.
- **Money movement over email** — wire-transfer authorization requested through email alone, with no out-of-band confirmation.

Why this message is unsafe

This is the textbook Business Email Compromise pattern that cost Google and Facebook over \$100 million. It weaponizes authority and urgency while explicitly engineering secrecy so the victim cannot verify with anyone. No legitimate executive asks finance to bypass procedure and keep a wire transfer secret. The lookalike domain confirms intent.

Triage verdict: MALICIOUS → Block & Escalate

Block the sender domain and escalate to the security team. Do not interact.

6.2 “Your Account Security Alert” (Credential Harvesting)

Attack class: Mass phishing — fake security alert with credential-harvest page

From: Microsoft Support <support@logins-updates.com>
Subject: FW: Urgent: Your Account Security Alert

Body: Unusual sign-in detected. Sign in below to secure your account.

Link: <https://account.microsoft.com.logins-updates.com/verify>

Attach: [Security_Update_2024.iso](#)

Red flags identified

- **Sender-domain mismatch** — “Microsoft Support” actually routes from logins-updates.com.
- **Fake forwarded chain** — the “FW:” prefix manufactures a sense of an existing, legitimate thread.
- **Deceptive subdomain link** — read right-to-left: the true root is logins-updates.com, not microsoft.com.
- **Activity alert that links out** — an alarmist sign-in warning pointing straight to a login page instead of advising manual navigation.
- **Dangerous attachment** — a .iso file — an uncommon extension used to smuggle executables past filters.

Why this message is unsafe

Every layer is a disguise. The display name borrows Microsoft’s trust; the URL hides a malicious root domain behind a microsoft.com-looking label; the .iso attachment is a known malware-delivery container. The goal is to harvest credentials on a spoofed Sign-In page (and possibly drop malware). A real provider tells you to navigate to the site yourself, never to sign in through an emailed link.

Triage verdict: MALICIOUS → Block & Escalate

Block the sender domain and escalate to the security team. Do not interact.

6.3 “CEO Lost-Wallet” SMS (Smishing / BEC)

Attack class: Smishing — traveling-executive BEC over text

Channel: SMS — unknown number

Message: I lost my wallet at the airport. Need you to wire transfer funds for my flight immediately. – CEO

Red flags identified

- **Channel mismatch** — a wire-transfer request arriving by SMS from an unknown number rather than a known corporate channel.
- **Urgency trigger** — “immediately” plus a stranded-executive story to force a fast, emotional response.
- **Authority impersonation** — signed “CEO” to borrow executive authority without any verifiable identity.
- **Money movement request** — funds requested before any out-of-band identity confirmation.

Why this message is unsafe

The “lost wallet” scenario is a classic BEC test of response to executive authority. It moves the attack to SMS, where there are no headers to inspect and the recipient cannot easily verify the sender. The correct

response is to verify via a known, secondary channel (call the executive's known number) — never to act on the text.

Triage verdict: SUSPICIOUS → Warn & Verify

Warn the user and verify out-of-band before any action is taken.

6.4 “Subscription Payment Failed” (SaaS Brand Impersonation)

Attack class: Mass phishing — payment-failure lure with fake billing link

From: ChatGPT Billing <no-reply@chatgpt-billing.net>
Subject: Urgent: ChatGPT Payment Failure
Body: Your subscription payment failed. Update your billing information to avoid service interruption.
Button: Update Billing → hidden shortened link (bit.ly/secure-billing)

Red flags identified

- **Brand impersonation** — mimics a familiar SaaS brand (ChatGPT) to borrow trust.
- **Finance-related urgency** — “avoid service interruption” pressures the user to act before thinking.
- **Hidden shortened link** — the “Update Billing” button hides its destination behind a URL shortener — no visible root domain to verify.
- **Off-brand sender domain** — chatgpt-billing.net is not the brand's real domain.
- **Request for payment details** — prompts a billing-information change through an emailed link.

Why this message is unsafe

This lure tests finance-related urgency. The shortened link is the key tell: legitimate billing emails link to the provider's real domain, not an opaque bit.ly slug. Because the true destination is concealed, the safe action is to ignore the button entirely and navigate to the provider's site directly to check billing status.

Triage verdict: SUSPICIOUS → Warn & Verify

Warn the user and verify out-of-band before any action is taken.

6.5 Q3 Project Status Update (Legitimate — Control Sample)

Attack class: Benign internal email — included to calibrate the triage process

From: Project Manager <sarah.lee@company.com>
Subject: Q3 Project Status Update - Non-Urgent
Body: Hi Team, please review the attached project status for Q3 at your earliest convenience. No immediate action is required. Thanks, Sarah.
Attach: Q3_Status.pdf

Red flags identified

- **None of significance** — sender domain matches the company; no urgency, secrecy, or sensitive-info request; a standard .pdf attachment; tone consistent with a known colleague.

Why this message is unsafe

Not every message is an attack — training to a 0% click rate by treating everything as malicious is itself a failure mode. This control sample shows what “safe” looks like: a matching internal domain, explicit “no immediate action required,” a normal attachment type, and no cognitive triggers. After a quick sender check it can be safely closed. (If anything were unexpected, an out-of-band verification with Sarah still resolves it.)

Triage verdict: SAFE → Close

Close — no indicators of compromise after verification.

7. The Phishing Triage Toolkit

The project mandate is to build a non-expert triage checklist and a clear decision tree for incoming threats, where every triage event ends in a definitive action. This section delivers that toolkit.

7.1 Decision tree

Every incoming suspicious message is sorted into one of three buckets, each with a single mandated outcome.

SAFE	SUSPICIOUS	MALICIOUS
↓ CLOSE	↓ WARN USER	↓ BLOCK & ESCALATE
Sender domain verified, no triggers, normal attachment. No action needed beyond closing.	Some indicators but unconfirmed. Warn the user and verify out-of-band before acting.	Clear indicators (spoofed domain, malware attachment, BEC). Block the domain, report, and escalate to security.
Non-negotiable rule No triage event is left open-ended. Every message resolves to Close , Warn User , or Block Domain & Escalate .		

7.2 Analyst standard operating procedure (header & URL checks)

1. **Expand the header.** Read the real From address and Return-Path, not the display name.
2. **Check authentication.** Confirm SPF, DKIM, and DMARC results; failures on a domain that matches your own are a strong malicious signal.
3. **Parse every URL right-to-left.** Identify the true root domain immediately before the first single slash; ignore reassuring subdomain labels.
4. **Expand shorteners safely.** Never live-click; use a preview/sandbox to reveal the destination.
5. **Inspect attachments.** Flag uncommon extensions (.iso, .js, .scr, .html) and anything that doesn't match the stated content.
6. **Score the psychology.** Note any authority, urgency, secrecy, or sensitive-info request.
7. **Assign a bucket and act.** Close, Warn, or Block & Escalate — then report through the internal tool so the threat can be purged from every inbox.

8. Employee Red-Flag Checklist

A one-page, non-expert checklist (the “Red Flag Checklist” suggested in the project brief). If a message trips two or more boxes, stop and report it. Print or pin this for everyday use.

Sender

- ☐ Does the real email address (not just the display name) match the organization it claims to be from?
- ☐ Is this the first time this “known” person has emailed me from this address?

Links & attachments

- ☐ Reading the URL right-to-left, is the true root domain the one I expect?
- ☐ Is the link a shortener (bit.ly, etc.) hiding its real destination?
- ☐ Is the attachment an unusual type (.iso, .js, .scr, .html)?

Tone & request

- ☐ Is it pushing urgency, secrecy, or asking me to bypass a normal procedure?
- ☐ Does it ask for a password, MFA code, or payment/banking change by email or text?
- ☐ Is it an unexpected sign-in alert, prize, legal threat, or QR-code prompt?

If in doubt

- ☐ PAUSE — apply the five-minute rule and stop interacting.
- ☐ VERIFY — contact the sender through a known, separate channel (not the reply button).
- ☐ REPORT — use the internal reporting tool; do not just delete.

9. Building Resilience: Simulation & Ethics

Awareness becomes instinct only through safe, realistic practice. Organizations that rely solely on filters leave people unprepared for the threats that inevitably slip through. The aim of a simulation is never to trick or shame employees — it is to mirror real-world tactics so staff can rehearse the Pause-Verify-Report loop safely, turning theoretical awareness into a measurable, active defense layer.

9.1 Ethical template design

DO	DON'T
• Mimic real brands and use persuasive emotional triggers. • Include subtle, realistic anomalies (a slightly misspelled domain, a mismatched reply-to).	• Scare users to death — avoid family emergencies, termination threats, or extreme distress. • Use obvious, easily verifiable lies (impersonating a colleague at the next desk. • Train to a 0% click rate with comically bad spelling; mirror a real attacker's sophistication.

9.2 The continuous loop

Effective programs run a cycle: Simulate → Measure Risk → Deliver Microlearning → Strengthen Culture → repeat. Each pass converts a missed indicator into a learning opportunity rather than a failure.

10. Conclusion

Phishing exploits the space between a technical control and a human reaction. This project closed that gap analytically: it mapped the threat taxonomy (mass, spear, whaling, and channels beyond the inbox), exposed the technical disguises hidden in headers and URLs (including the right-to-left rule and the URL-shortener problem), and named the psychological triggers that push users to bypass logic.

Most importantly, it turned that understanding into a working toolkit: an eleven-point red-flag catalogue, five fully dissected sample messages each ending in a verdict, a three-bucket decision tree where every event resolves to Close, Warn, or Block & Escalate, and a one-page checklist any employee can use. Together these fortify the human firewall — the modern security perimeter.

The one rule that ends every analysis

Pause. Verify. Report. Recognize the trigger, confirm through a known out-of-band channel, and report rather than delete. Master that loop and the first “phish” you catch becomes the first of many.